

## **Executive Summary**

This vulnerability assessment evaluated the OWASP Juice Shop application within an authorized cybersecurity laboratory environment. OWASP ZAP was used to perform automated application discovery, passive analysis, and active vulnerability scanning. Findings generated by the automated scanner were subsequently reviewed and manually verified to distinguish confirmed vulnerabilities from potential or false-positive findings.

## **Assessment Scope**

Target:

OWASP Juice Shop

Target URL:

<http://192.168.64.1:3000>

Testing Environment:

Local cybersecurity laboratory

Tool:

OWASP ZAP

Testing Period:

September 28-December 3

Authorization:

Authorized educational testing environment

ScopeFilterInput VectorsCustom VectorsTechnologyPolicy

Starting Point:

http://192.168.64.1:3000

Select...

Policy:

Default Policy

Context:

JuiceShop-Lab

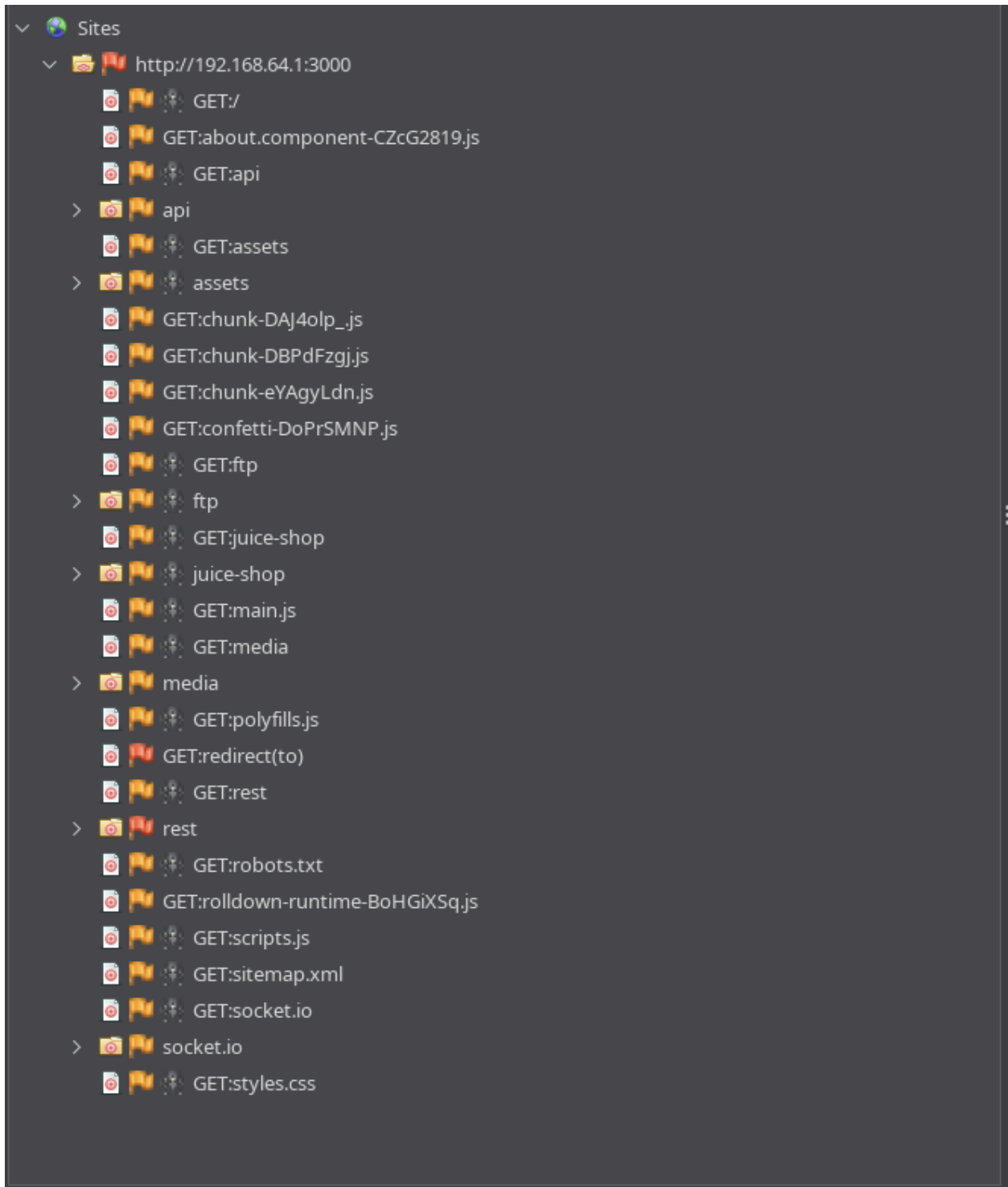
User:

Recurse:☒

Show Advanced Options☒

?

Start ScanResetCancel



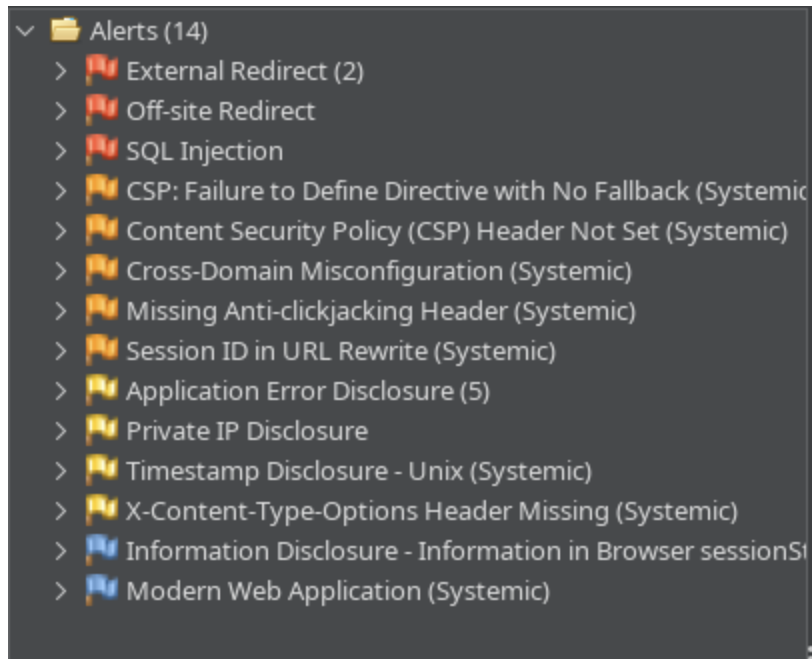
## Methodology

1. Define assessment scope
2. Configure ZAP Context
3. Explore application
4. Spider application

5. Passive scanning
6. Active scanning
7. Review alerts
8. Select findings
9. Manually verify findings
10. Analyze risk
11. Develop remediation recommendations
12. Generate final report

[illegible]

## Technical Findings



## V-001 — SQL Injection

Confirmed

### Description

OWASP ZAP's active scanner identified a potential SQL injection vulnerability in the `q` query-string parameter of the Juice Shop product-search endpoint. ZAP assigned the finding a High risk rating but Low confidence. The scanner's test resulted in an HTTP 500 Internal Server Error.

### Automated Detection

| Field   | ZAP result    |
|---------|---------------|
| Finding | SQL Injection |

Risk            **High**

Confidence    **Low**

URL            `http://192.168.64.1:3000/rest/products/search?q=...`

Parameter    `q`

Attack        `' ( /` quote-based input

Evidence      `HTTP/1.1 500 Internal Server Error`

CWE           **CWE-89**

Scanner       Active Scan

Input vector    URL Query String

## Manual Verification

The finding was manually tested by establishing a baseline response using a normal search query and then submitting controlled SQL injection test input to the `q` parameter. The responses were compared to determine whether the application's behavior was

consistent with SQL injection. Manual testing was performed against the affected **q** parameter. A baseline request using **q=apple** returned HTTP 200 and three matching products. A Boolean-based SQL injection test using **q=' OR '1'='1** also returned HTTP 200, but caused the endpoint to return a substantially larger product set rather than only the products matching "apple."

## Evidence

SQL Injection

URL: http://192.168.64.1:3000/rest/products/search?q=%27%28

Risk: High

Confidence: Low

Parameter: q

Attack: 1

Evidence: HTTP/1.1 500 Internal Server Error

CWE ID: 89

WASC ID: 19

Source: Active (4018 - SQL Injection)

Input Vector: URL Query String

Description: SQL injection may be possible.

Other Info:

Solution: Apply the principle of least privilege by using the least privileged database user possible. In particular, avoid using the 'sa' or 'sa-owner' database users. This does not eliminate SQL injection, but minimizes its impact. Grant the minimum database access that is necessary for the application.

Reference: https://cheatsheetseries.owasp.org/cheatsheets/SQL\_injection\_Prevention\_Cheat\_Sheet.html

Alert Tags:

| Key             | Value                                                                             |
|-----------------|-----------------------------------------------------------------------------------|
| POLICY_SEQUENCE |                                                                                   |
| OWASP_2021_A03  | https://owasp.org/Top10/2021/A03_2021-Injection/                                  |
| PCI_DSS         | https://www.zaproxy.org/docs/desktop/reports/common-library/alerttags/#compliance |
| CWE-89          | https://www.mitre.org/data/definitions/89.html                                    |
| POLICY_QA_CICD  |                                                                                   |

```
⌘(user@parrot)-[~]
$ curl -i http://192.168.64.1:3000/rest/products/search?q=apple
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
K-Content-Type-Options: nosniff
K-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
K-Recruiting: /#/jobs
Content-Type: application/json; charset=utf-8
Content-Length: 921
ETag: W/"399-qfU9ELHXPMIt0Ys837fOfzghBgC"
Vary: Accept-Encoding
Date: Tue, 29 Sep 2026 16:53:25 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"status":"success","data":[{"id":1,"name":"Apple Juice (1000ml)","description":"The all-time classic.","price":1.99,"deluxePrice":0.99,"image":"apple_juice.jpg","createdAt":"2026-09-29 15:25:11.351 +00:00","updatedAt":"2026-09-29 15:25:11.351 +00:00","deletedAt":null},{id":24,"name":"Apple Pomegranate","description":"Finest pressings of apples. Allergy disclaimer: Might contain traces of worms. Can be <a href='/recycle/'>sent back to us</a> for recycling.","price":0.89,"deluxePrice":0.89,"image":"apple_pressings.jpg","createdAt":"2026-09-29 15:25:11.353 +00:00","updatedAt":"2026-09-29 15:25:11.353 +00:00","deletedAt":null},{id":47,"name":"Pineapple Juice (1000ml)","description":"Tropical refreshment from the finest sun-ripened pineapples.","price":2.99,"deluxePrice":2.99,"image":"pineapple_juice.png","createdAt":"2026-09-29 15:25:11.354 +00:00","updatedAt":"2026-09-29 15:25:11.354 +00:00","deletedAt":null}]}⌘(user@parrot)-[~]
$ curl -i http://192.168.64.1:3000/rest/products/search?q=%27%20OR%20%271%27%3D%271%
HTTP/1.1 200 OK
Access-Control-Allow-Origin: *
K-Content-Type-Options: nosniff
K-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
K-Recruiting: /#/jobs
Content-Type: application/json; charset=utf-8
Content-Length: 16563
ETag: W/"40b3-2Ru195uZDoTL1EnEdZCBcILQmHU"
Vary: Accept-Encoding
Date: Tue, 29 Sep 2026 16:53:46 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"status":"success","data":[{"id":1,"name":"Apple Juice (1000ml)","description":"The all-time classic.","price":1.99,"deluxePrice":0.99,"image":"apple_juice.jpg","createdAt":"2026-09-29 15:25:11.351 +00:00","updatedAt":"2026-09-29 15:25:11.351 +00:00","deletedAt":null},{id":24,"name":"Apple Pomegranate","description":"Finest pressings of apples. Allergy disclaimer: Might contain traces of worms. Can be <a href='/recycle/'>sent back to us</a> for recycling.","price":0.89,"deluxePrice":0.89,"image":"apple_pressings.jpg","createdAt":"2026-09-29 15:25:11.353 +00:00","updatedAt":"2026-09-29 15:25:11.353 +00:00","deletedAt":null},{id":6,"name":"Banana Juice (1000ml)","description":"Monkeys love it the most.","price":1.99,"deluxePrice":1.99,"image":"banana_juice.jpg","createdAt":"2026-09-29 15:25:11.352 +00:00","updatedAt":"2026-09-29 15:25:11.352 +00:00","deletedAt":null},{id":52,"name":"Basil Smoothie","description":"A unique blend of fresh basil and ginger for a healthy kick.","price":2.99,"deluxePrice":2.99,"image":"basil_smoothie.png","createdAt":"2026-09-29 15:25:11.354 +00:00","updatedAt":"2026-09-29 15:25:11.354 +00:00","deletedAt":null},{id":51,"name":"Berry Juice (1000ml)","description":"A delicious blend of fresh forest berries.","price":3.49,"deluxePrice":3.49,"image":"berry_juice.png","createdAt":"2026-09-29 15:25:11.354 +00:00","updatedAt":"2026-09-29 15:25:11.354 +00:00","deletedAt":null},{id":42,"name":"Best Juice Shop Salesman Artwork","description":"Unique digital painting depicting Stan, our most qualified and almost profitable salesman. He made a successful career in selling used ships, coffins, crypts, crosses, real estate, life insurance, restaurant supplies, voodoo enhanced asbestos and courtroom souvenirs before <em>finally</em> adding his expertise to the Juice Shop marketing team.","price":5000,"deluxePrice":5000,"image":"artwork2.jpg","createdAt":"2026-09-29 15:25:11.354 +00:00","updatedAt":"2026-09-29 15:25:11.354 +00:00","deletedAt":null},{id":53,"name":"Braga (500ml)","description":"Traditional Balkan drink made from fermented millet. Lightly sweet-sour, refreshing, and naturally energizing.","price":2.49,"deluxePrice":2.49,"image":"braga.jpg","createdAt":"2026-09-29 15:25:11.354 +00:00","updatedAt":"2026-09-29 15:25:11.354 +00:00","deletedAt":null},{id":30,"name":"Carrot"}]
```

## Impact

Successful exploitation of the SQL injection vulnerability could allow an attacker to manipulate the application's database query through the **q** parameter. Depending on the

privileges of the application's database account and the affected query, this could result in unauthorized access to database information, modification or deletion of data, application-logic bypass, or disruption of database operations.

## Remediation

Replace dynamically constructed SQL statements with parameterized queries/prepared statements. Validate the `q` parameter according to expected search-input requirements and ensure that the application's database account operates with the minimum privileges necessary. Database error details should not be exposed to users. After remediation, repeat the SQL injection tests to verify that SQL syntax supplied through `q` is treated as data rather than executable SQL.

## V-002 — External Redirect

**Severity:** High

**Confidence:** Medium

**Status:** Confirmed

**Affected URL:** <http://192.168.64.1:3000/redirect?to=https://github.com/juice-shop/juice-shop>

**Parameter:** to

### Description:

OWASP ZAP identified an external redirect associated with the Juice Shop application. The alert was investigated to determine whether the redirect destination could be influenced by user-controlled input.

### Automated Detection:

ZAP's Active Scanner identified two instances of the External Redirect alert. The affected request and response were reviewed to identify the redirect mechanism.

### Manual Verification:

The redirect functionality was manually tested by supplying an external URL through the `to` parameter:

<http://192.168.64.1:3000/redirect?to=https://github.com/juice-shop/juice-shop>

The application returned an HTTP 302 Found response with the following `Location` header:

`Location:` <https://github.com/juice-shop/juice-shop>

This confirms that the application accepts an externally controlled destination and instructs the client to navigate to the external domain.

## Evidence

**Off-site Redirect**

URL: <http://192.168.64.1:3000/redirect?to=https://github.com/juice-shop/juice-shop>

Risk:  High

Confidence: Medium

Parameter: to

Attack:

Evidence:

CWE ID: 601

WASC ID: 38

Source: Passive (10028 - Off-Site Redirect)

Input Vector:

Description:

Open redirects are one of the OWASP 2010 Top Ten vulnerabilities. This check looks at user-supplied input in query string parameters and POST data to identify where open redirects might be possible. Open redirects occur when an application allows user-supplied input (e.g. <https://nottrusted.com>) to control an off-site destination. This is generally a pretty accurate way to find where 301 or 302 redirects could be exploited by spammers or phishing attacks.

Other Info:

The 301 or 302 response to a request for the following URL appeared to contain user input in the location header:

<http://192.168.64.1:3000/redirect?to=https://github.com/juice-shop/juice-shop>

Solution:

To avoid the open redirect vulnerability, parameters of the application script/program must be validated before sending 302 HTTP code (redirect) to the client browser. Implement safe redirect functionality that only redirects to relative URIs, or a list of trusted domains.

Reference:

[https://cheatsheetsseries.owasp.org/cheatsheets/Unvalidated\\_Redirects\\_and\\_Forwards\\_Cheat\\_Sheet.html](https://cheatsheetsseries.owasp.org/cheatsheets/Unvalidated_Redirects_and_Forwards_Cheat_Sheet.html)

<https://cwe.mitre.org/data/definitions/601.html>

Alert Tags:

| Key            | Value                                                                                                                                             |
|----------------|---------------------------------------------------------------------------------------------------------------------------------------------------|
| CWE-601        | <a href="https://cwe.mitre.org/data/definitions/601.html">https://cwe.mitre.org/data/definitions/601.html</a>                                     |
| POLICY_QA_STD  |                                                                                                                                                   |
| POLICY_PENTEST |                                                                                                                                                   |
| OWASP_2017_A01 | <a href="https://owasp.org/www-project-top-ten/2017/A1_2017-Injection.html">https://owasp.org/www-project-top-ten/2017/A1_2017-Injection.html</a> |
| POLICY_DEV_STD |                                                                                                                                                   |

```
DAEDMAC1010:dae_6month_ad Adult$ curl -i http://192.168.64.1:3000/redirect?to=https://github.com/juice-shop/juice-shop
HTTP/1.1 302 Found
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Location: https://github.com/juice-shop/juice-shop
Vary: Accept, Accept-Encoding
Content-Type: text/plain; charset=utf-8
Content-Length: 62
Date: Tue, 29 Sep 2026 17:25:19 GMT
Connection: keep-alive
Keep-Alive: timeout=5

Found. Redirecting to https://github.com/juice-shop/juice-shopDAEDMAC1010:dae_6month_ad Adult$
```

## Impact:

If the redirect destination is externally controllable, an attacker could potentially use the application's trusted URL to redirect users to an attacker-controlled website, potentially supporting phishing or other social-engineering activity.

## Remediation:

Restrict redirects to approved internal paths or an allowlist of trusted destinations. Do not allow arbitrary user-supplied external URLs to determine redirect destinations. Re-test the affected endpoint after remediation.

# V-003 — CSP: Failure to Define Directive with No Fallback

**Description:**

The application's Content Security Policy contains a directive that does not have an explicitly defined fallback directive. CSP directives control which types of resources a browser is permitted to load or execute. When a directive does not define its own source list and does not inherit a fallback from another applicable directive, the browser may use its default behavior for that resource type.

**Affected Application:**

# OWASP Juice Shop

**Affected URL:**

http://192.168.64.1:3000/assets

## Manual Verification

The finding was manually verified by inspecting the HTTP response from the affected endpoint. The `/assets` endpoint returned an HTTP 301 response containing the following Content-Security-Policy header:

```
Content-Security-Policy: default-src 'none'
```

This confirms the CSP configuration identified by ZAP is present in the application's response.

## Evidence

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |     |                                                                                                                                                                                       |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p><b>CSP: Failure to Define Directive with No Fallback</b></p> <p>URL: <a href="https://192.168.64.1:3000/assets">https://192.168.64.1:3000/assets</a></p> <p>Risk: <b>High</b> Medium</p> <p>Confidence: High</p> <p>Parameter: Content-Security-Policy</p> <p>Attack:</p> <p>Evidence: default-src: none</p> <p>CVE ID: 693</p> <p>WASC ID: 13</p> <p>Source: Passive (10005 - CSP)</p> <p>Alert Reference: 10005-13</p> <p>Input Vector:</p> <p>Description:</p> <p>The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything.</p> <p>Other Info:</p> <p>The directives[] &amp;name-ancestor, form-action &amp;name are among the directives that do not fallback to default-src.</p> <p>Solution:</p> <p>Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content Security Policy header.</p> <p>Reference:</p> <p><a href="https://www.w3.org/TR/CSP/">https://www.w3.org/TR/CSP/</a></p> <p><a href="https://canisus.com/#search/content-security-policy">https://canisus.com/#search/content-security-policy</a></p> <p><a href="https://content-security-policy.com/">https://content-security-policy.com/</a></p> <p>Alert Tags:</p> |     |                                                                                                                                                                                       |
| SYSTEMIC                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | Key | Value                                                                                                                                                                                 |
| CVE_693                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |     | <a href="https://www.zapmyorg.org/docs/desktop/addons/common-library/alerttags#systemic">https://www.zapmyorg.org/docs/desktop/addons/common-library/alerttags#systemic</a>           |
| OWASP_2017_A06                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |     | <a href="https://raw.githubusercontent.com/OWASP/2017/A6_2017/Security_Misconfiguration.html">https://raw.githubusercontent.com/OWASP/2017/A6_2017/Security_Misconfiguration.html</a> |
| OWASP_2025_A02                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |     | <a href="https://owasp.org/Top10/2025/A02_2025-Security_Misconfiguration/">https://owasp.org/Top10/2025/A02_2025-Security_Misconfiguration/</a>                                       |
| POLICY_CSP_617D                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |     |                                                                                                                                                                                       |

```
[DAEDMAC1010:dae_6month_ad Adult$ curl -s -D - -o /dev/null "http://192.168.64.1:3000/assets" ]
HTTP/1.1 301 Moved Permanently
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Content-Type: text/html; charset=UTF-8
Content-Length: 156
Content-Security-Policy: default-src 'none'
Location: /assets/
Vary: Accept-Encoding
Date: Tue, 29 Sep 2026 17:52:11 GMT
Connection: keep-alive
Keep-Alive: timeout=5

DAEDMAC1010:dae_6month_ad Adult$ █
```

Potential Impact

The finding indicates that the application's CSP configuration may not explicitly define all applicable resource directives. This can reduce the clarity and predictability of the policy and may limit CSP's effectiveness as a defense-in-depth control. The actual security impact depends on the resource types used by the application and the other CSP directives configured.

Recommended Remediation

Review the application's CSP and explicitly define appropriate directives for the resource types used by the application. Maintain restrictive source values and use `default-src 'none'` as a restrictive baseline where appropriate. Test the resulting policy to ensure that required application functionality continues to operate while unnecessary resource sources remain blocked.

Risk Priority

| ID | Finding | Risk Level | Potential Impact | Exploitability | Priority | Recommended Action |
|----|---------|------------|------------------|----------------|----------|--------------------|
|----|---------|------------|------------------|----------------|----------|--------------------|

|              |                                                   |               |                                                                                                                                                       |                                                                                                                              |                    |                                                                                                                         |
|--------------|---------------------------------------------------|---------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------|--------------------|-------------------------------------------------------------------------------------------------------------------------|
| <b>V-001</b> | SQL Injection                                     | <b>High</b>   | Potential unauthorized database access, data disclosure, modification, or other application compromise depending on the vulnerable query              | <b>High</b> — demonstrated through a crafted input                                                                           | <b>1 — Highest</b> | Remediate first; use parameterized queries/prepared statements, input validation, and least-privilege database accounts |
| <b>V-002</b> | External Redirect                                 | <b>Medium</b> | Users can potentially be redirected from a trusted application URL to an external website, which could support phishing or malicious-content delivery | <b>High</b> — demonstrated by the 302 response and external Location header                                                  | <b>2</b>           | Restrict redirect destinations to approved domains or internal relative paths                                           |
| <b>V-003</b> | CSP: Failure to Define Directive with No Fallback | <b>Low</b>    | May reduce the effectiveness or predictability of CSP as a defense-in-depth control.                                                                  | <b>Low/Context-dependent</b> — ZAP identified the CSP configuration, but manual test did not demonstrate direct exploitation | <b>3</b>           | Review and explicitly define appropriate CSP directives; retain restrictive source policies                             |